

OWASP Top 10 Web App Security Risks

CompTIA PenTest+ (PT0-003)

Domain: 4.0 Attacks and Exploits

Objectives:

- 4.1: Given a scenario, analyze output to prioritize and prepare attacks.
- 4.5: Given a scenario, perform web application attacks using the appropriate tools.

Video Overview

This video will introduce you to the OWASP Top 10 Web Application Security Risks, a widely recognized list that outlines the most common and impactful security vulnerabilities in web applications. Understanding these risks is foundational for anyone involved in web development, security, or penetration testing, as it equips you with the knowledge to identify, prevent, and mitigate potential attacks. By exploring these top risks, you will gain insights that are directly applicable to preparing for the PenTest+ exam and for protecting real-world web applications in your future career.

Key Topics Covered

- OWASP Top 10 List: Understanding its purpose and importance for developers and penetration testers.
- Broken Access Control: Improper enforcement of access policies leading to unauthorized access and data manipulation.
- Cryptographic Failures: Risks associated with absent, weak, or improperly managed encryption for sensitive data.
- Injection Attacks: When untrusted data is executed as commands or queries, including SQL, OS command, and LDAP injection.
- Insecure Design: The lack of security considerations in the initial design phase of software development.
- Security Misconfiguration: Preventable oversights like default credentials, weak hardening, and verbose error handling.
- Vulnerable and Outdated Components: The use of unsupported or out-of-date software and components within a web application.

- Identification and Authentication Failures: Weak authentication mechanisms enabling automated attacks like credential stuffing and brute force, and the importance of MFA.
- Software and Data Integrity Failures: Vulnerabilities related to untrusted plugins, libraries, and insecure CI/CD pipelines.
- Security Logging and Monitoring Failures: Inadequate logging and monitoring leading to undetected data breaches.
- Server-Side Request Forgery (SSRF): When a web application fetches remote resources without validating user-supplied URLs, potentially exposing internal networks.

Student Notes Section